

Poonawalla Fincorp Limited

Information Technology Management Policy

Effective Date: 17.10.2025

Approval Date: 17.10.2025

Version No.: 13.0

Approved By: Board of Directors

Policy Owner: Information Technology

This document is confidential in nature and supersedes any existing Policy on IT Management in the Company and should be read in conjunction with the most recent policies and procedures documented.

INFORMATION TECHNOLOGY MANAGEMENT POLICY

Document review and approval

Document Control

Document Name	IT Management Policy
Frequency of review	Yearly
Effective Date	17.10.2025
Approved by	Board of Directors
Policy Owner	Information Technology
Recommended by	Head IT Risk, Program Management and Transformation
Reviewed by	Chief Technology Officer

Version Control

Date	Version	Change Description (in brief)
-	-	Name of the Company changed to Poonawalla Fincorp Limited w.e.f 22.07.2021
27.10.2021	7.0	To align with the regulatory requirements
12.05.2022	8.0	Updated CISO name and Terms of Reference to be aligned as per modified ITSC Charter
21.10.2022	9.0	- Added ToR for IT Steering Committee - Update the composition of IT Steering Committees - Added Backup and Archival for cloud environment
20.10.2023	10.0	- Added IT Training - Update the composition of IT Steering Committees - Update the Annexure A - Ownership change to Information Technology
18.01.2024	11.0	To align with regulatory requirements and that the proposed changes shall be effective from 01 April 2024.
25.10.2024	12.0	Ownership change to Information Technology
17.10.2025	13.0	Minor document update in team structure

Table of Contents

Introduction	6
1. Purpose	6
2. Objective:.....	8
3. Applicability.....	8
4. Compliance.....	8
5. Policy Control.....	9
Policy Sections (Part A)	9
6. IT Strategy and Planning.....	9
7. IT Strategy Committee	11
8. IT Steering Committees	11
9. IT organizational structure.....	12
10. Enterprise Architecture	13
11. Supplier Management	14
12. Business Continuity Planning and Disaster Recovery	15
13. Program & Project Management.....	17
14. Change Management.....	18
Policy Sections (Part B)	19
15. Asset Management	19
16. Incident & Problem Management.....	20
16.1. Incident Management	20
16.2. Problem Management.....	20
17. Backup and Archival.....	21
18. User Collaboration & Email.....	22
19. IT Outsourcing.....	23
20. Management Information System	23
21. IT Risk Management	24
22. Capacity Management.....	25
23. Acceptable Usage	25
24. IT Training.....	26
25. Web Presence (Intranet & Internet) and Communications.....	26
26. Policy Governance	26
26.1. Roles & Responsibilities.....	26

26.2.	Bodies of Governance (BOG)	28
26.3.	RACI Matrix	29
26.4.	Annexure A.....	31

Classification | INTERNAL

Introduction

1. Purpose

The purpose of this document is to establish the policy and direction encompassing all the strategic and operational areas of Information Technology and its use in Poonawalla Fincorp. Ltd. The IT Management Policy is backed by a set of Standards, Guidelines, Standard Operating Procedures (SOP) and Templates detailing each process and activities of each section of the Policy. A mapping of the documents is given in Annexure A.

The following table lists each IT Policy along with its stated purpose. It may be noted that the Part A of the policies have more involvement of Business stakeholders while part B must do more with internal management of IT.

#	Policy	Stated Purpose
Part A (Policies related to Business-IT)		
1	IT Strategy & Planning	To ensure that IT priorities and projects are in alignment with business priorities and are executed in a time bound manner with adequate funding to realize them.
2	Enterprise Architecture	To ensure that the IT supports the business requirements in a scalable, reliable, secure, efficient, and cost-effective manner.
3	Supplier Management	To ensure that PFL is able to procure the best-in-class technology products and services in an objective manner, while adhering to industry best practices.
4	Business Continuity Planning and Disaster Recovery	To protect business data in the event of disaster of any form and provide continuity of business in such events.
5	Program & Project Management	To ensure predictability of all IT projects on Time, Quality and Cost parameters
6	Change Management	To ensure each change has been adequately evaluated against impact on business, IT and Cost before being approved and implemented.
PART B (Policies primarily related to IT Management and IT Operations)		

7	Asset Management	To optimally manage assets through the entire lifecycle from procurement until disposal.
8.1	Incident Management	To provide the incident logging and resolution capability to the customers of IT.
8.2	Problem Management	To ensure resolution to the problems underlying recurring incidents or otherwise are accurately identified and resolved.
9	Backup and Archival	To safeguard PFL data against events such as corruption, virus attacks or malfunctioning of production environment in Data Centre
10	IPV6	To Migrate all customer facing website which are currently not using IPV6.
11	User Collaboration and Email	To enable collaboration among PFL users by providing timely access to information.
12	IT Outsourcing	To identify risks associated with outsourcing the IT function of the Company to external parties and establish appropriate controls to ensure security in line with the Outsourcing Policy of PFL.
13	Management Information System.	To support a robust and comprehensive Management Information System (MIS) in respect of various business functions as per the needs of the business
14	IT Risk Management	To create IT risk management process which ensures compliance with functional, security, performance and applicable regulatory requirements is followed for all IT assets/processes/services.
15	Acceptable Usage	To ensure business purposes and authorized users shall adhere to safe and acceptable usage practices that do not disrupt business or bring disrepute to Organisation.
16	Web Presence (Intranet & Internet) and Communications	To ensure that the information published on websites is accurate, consistent, and current.

2. Objective:

The objective of the Information Technology policy is to set the guiding principles for establishing IT operational procedures and at the same time to achieve Confidentiality, Integrity and Availability ("CIA") of information systems used by Users of Organisation.

3. Applicability

The policy is applicable to all locations of Organisation including all IT assets, all IT processes, all business processes supported by IT and all employees, partners, casual workers and outsourcing partners of organisation (hereafter referred to as 'PFL GROUP' or 'PFL' in this document).

4. Role of Board of Directors:

- a) to approve the strategies and policies related to IT, Information Assets, Business Continuity, Information Security, Cyber Security (including Incident Response and Recovery Management/ Cyber Crisis Management)
- b) to review the strategies and policies at least annually.

5. Role of Senior Management:

The Senior Management of PFL shall, inter alia, ensure:

- a) Execution of the IT Strategy approved by the Board.
- b) IT/ IS and their support infrastructure are functioning effectively and efficiently.
- c) Necessary IT risk management processes are in place and create a culture of IT risk awareness and cyber hygiene practices at PFL.
- d) Cyber security posture of PFL is robust.
- e) Overall, IT contributes to productivity, effectiveness and efficiency in business operations.

6. Role of Head of IT Function:

PFL shall appoint a sufficiently senior level, technically competent and experienced official in IT related aspects as Head of IT Function.

The Head of IT Function shall, inter alia, be responsible for the following:

- (i) ensuring that the execution of IT projects/ initiatives is aligned with the PFL's IT Policy and IT Strategy.
- (ii) ensuring that there is an effective organisational structure to support IT functions.
- (iii) putting in place an effective disaster recovery setup and business continuity strategy/ plan.
- (iv) shall ensure effective assessment, evaluation and management of IT controls and IT risk, including the implementation of robust internal controls, to (i) secure PFL's information assets (ii) comply with extant internal policies, regulatory and legal requirements on IT related aspects.

Note: For the purpose of this para- CTO may be designated as Head of IT Function.

7. Compliance

All the employees, contractors and agency staff connected to Information Technology at PFL have to comply with this policy. Any deviation to the policy in respective areas must have prior approval of CIO / CTO (CTO means Chief Technology Officer and / or Chief Transformation Officer). Any breach of this policy shall be investigated and may result in the matter being treated as a disciplinary offence under and as per the code of conduct of the organisation.

8. Policy Control

In case of any changes/amendments in the IT strategies in line with the corporate strategies, Board Policy reviews and any other matter related to IT Governance, the Policy shall be reviewed and approved by Strategy Committee and shall be placed before the Board for approval.

Policy Sections (Part A)

9. IT Strategy and Planning

- a. **Purpose:** Purpose is to ensure that IT priorities and projects are in alignment with business priorities and are executed in a time bound manner with adequate funding to realize them.
- b. **Scope:** Scope of IT Strategy is to capture the Business Strategy of PFL at corporate level and functional levels and formulate an IT Strategy following a defined methodology as part of the Standard Operating Procedure.
- c. **Outcome:** Outcome of IT Strategy and Planning exercise is to have a comprehensive IT Strategy document along with the roadmap of IT projects and the budget that needs to be provisioned.
- d. **Stakeholders:** Stakeholders: Primary ownership of IT Strategy and Planning lies with CIO / CTO / Head IT. The RACI Matrix has listed stakeholders. All IT Strategy and Planning artefacts must be signed off by the IT Strategy Committee (ITSC) to come in force. PFL's ITSC shall be appointed by the MD.
- e. **Policy Statements**
 - I. The IT Strategy must capture the business strategy of the Company at Corporate and Functional levels and relate them to the required IT capabilities.

- II. PFL shall have a framework and methodology to create IT Strategy, which shall cover the following dimensions:
- i. Enabler of Business Strategy
 - ii. Innovation
 - iii. Cost Efficiency
 - iv. Risk Mitigation
 - v. Regulatory compliances
- III. Each new IT initiative must be supported by an appropriate business case; that includes business value, risks mitigated, customer impact, operational efficiency etc. in order to be part of the IT Roadmap.
- IV. Investment in an IT project shall have clear segregation of Capital and Operational expenditure. This shall follow the Total Cost of Ownership framework and will be plotted over a one-year time horizon.
- V. Confidentiality of Data: All budget information concerning price/rate assumed, size of project, vendors considered etc. is to be protected to ensure that it is not subject to misuse or passed on to third parties. Unauthorized disclosure of such information would be treated as breach of confidentiality, exposing the individual to disciplinary action.
- VI. Technology Refresh: Plan for the replacement of hardware and software in a timely manner before they reach End of Support (EOS).
- VII. Data Migration: For any migration need, PFL shall have a documented data migration process specifying a systematic process for data migration, ensuring data integrity, completeness, and consistency. The process shall, inter alia, contain provisions pertaining to signoffs from business users and application owners at each stage of migration, maintenance of audit trails, etc.
- VIII. To protect the Integrity of Information – Information shall remain accurate, error free and without unauthorized changes.
- IX. To ensure the Availability of Information – authorized users shall have access to critical business information when required.

- X. To ensure compliance to applicable laws, regulations, and guidelines.
 - XI. To ensure continuous delivery of critical services and products, which permits to recover its facility, information, and assets.
 - XII. To ensure all Users are aware of their responsibilities towards protecting Information.
 - XIII. To align with globally recognized standards for Information Security such as ISO 27001:2013.
 - XIV. Frequency: The ITSC shall meet at least on a quarterly basis.
- f. **Enforcement:** ITSC will monitor the adherence to IT Roadmap. Any unplanned IT initiative or project that may overshoot the approved IT budget, shall have to obtain ITSC approval.
- g. **Review:** IT Strategy and Planning is an annual exercise with a half yearly update to ITSC.

10. IT Strategy Committee

Composition of IT Strategy Committee (ITSC)

The ITSC shall consist minimum of three directors as members. The Chairperson of the ITSC shall be an independent director and have substantial IT expertise in managing/ guiding information technology initiatives. Further, all the members are technically competent.

“Substantial IT expertise” means the person has a minimum of seven years of experience in managing information systems and/or leading/ guiding technology/ cybersecurity initiatives/ projects. Such a member should also understand the business processes at a broader level and the impact of IT on such processes. Technically competent herein will mean the ability to understand and evaluate information systems and associated IT/ cyber risks.

11. IT Steering Committees

IT Steering Committee operating at an executive level and focusing on priority setting, resource allocation and project tracking.

Composition of IT Steering Committee:

The IT Steering Committee shall comprise of members with representation at Senior Management level from IT and business functions.

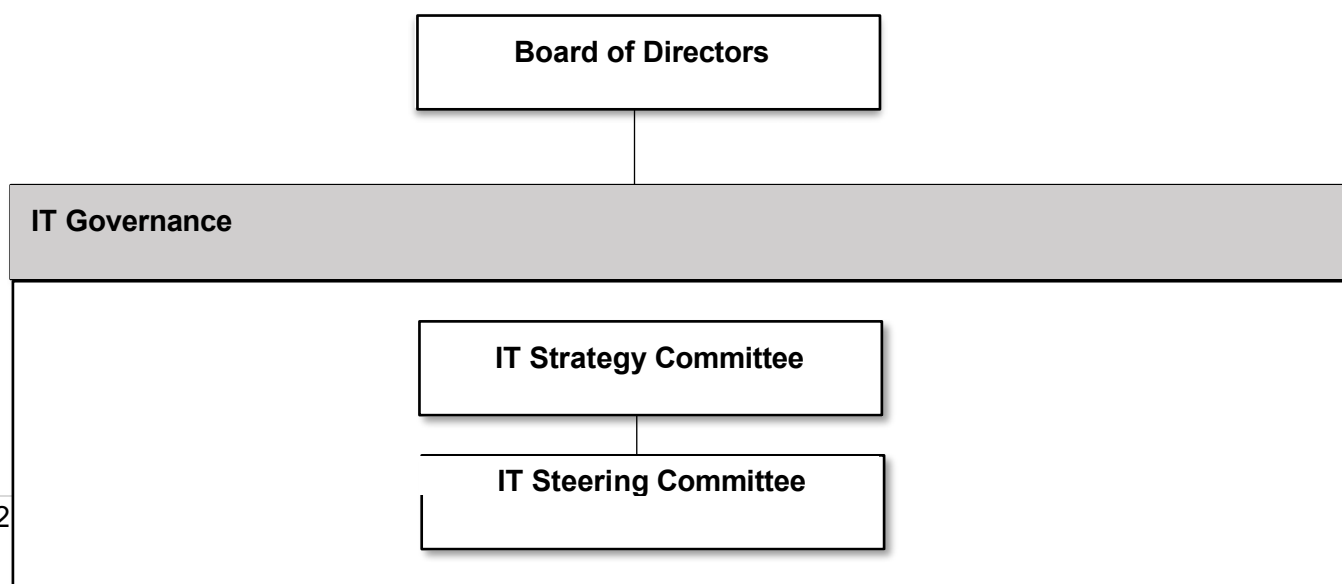
Terms of Reference of the IT Steering Committee

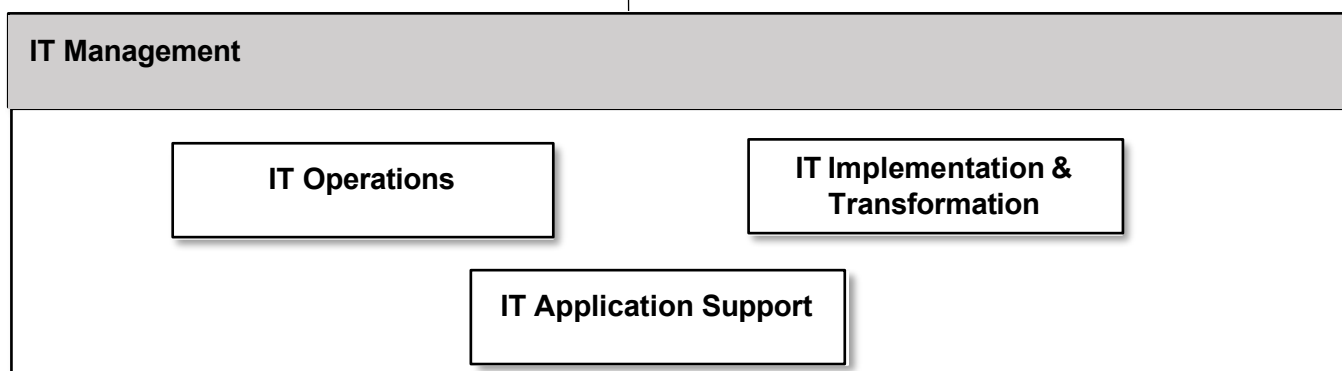
1. Review alignment of IT with business objectives.
2. Adapt IT to changing business needs and technology evolution.
3. Approving Information Security strategy, Information Security budget and Information Security resources.
4. Provide mandate, authority, resources, and budgets to IT projects.
5. Review IT landscape for suitability, adequacy, and effectiveness.
6. Assist the ITSC in strategic IT planning, oversight of IT performance, and aligning IT activities with business needs.
7. Oversee the processes put in place for business continuity and disaster recovery;
8. Ensure implementation of a robust IT architecture meeting statutory and regulatory compliance; and
9. Update ITSC and Managing Director periodically on the activities of IT Steering Committee.

12. IT organizational structure.

An IT organizational structure commensurate with the size, scale and nature of business activities carried out by the PFL with detailed IT portfolio, with Roles and responsibility shall be documented.

Refer IT organization structure for more details.





13. Enterprise Architecture

- a. **Purpose:** Purpose of Enterprise Architecture Policy is to ensure that the IT supports the business requirements in a scalable, reliable, secure, efficient, and cost-effective manner.
- b. **Scope:** Components of Enterprise Architecture comprises of.
 - I. Business Architecture: Business applications supporting various business processes.
 - II. Information Architecture: Taxonomy of business entities supported by various application databases. Business Intelligence and Enterprise Data warehouse are part of this.
 - III. Application Architecture: Technical design and models powering business applications.
 - IV. Infrastructure Architecture: Hardware and network supporting the business applications.
 - V. Security Architecture: Hardware and software controls to protect business applications.
- c. **Outcome:** Outcome of Enterprise Architecture is a set of Enterprise Architecture documents and templates that capture all the five dimensions of Enterprise Architecture.
- d. **Stakeholders:** Primary ownership of Enterprise Architecture lies with CTO / CIO. Other Stakeholders shall include IT Leadership Team.
- e. **Policy Statements**
 - I. PFL shall have an Enterprise IT Architecture Framework supported by the Principles, Standards, Guidelines and Templates.

II. PFL shall ensure that various requirements are aligned across applications to avoid duplication or interference of functionality of one department with the others. This shall be depicted in a Process-Application Map as part of Business Architecture.

- f. **Enforcement:** CTO / CIO shall conduct assessments of IT landscape and projects as per checklist mentioned above.
- g. **Reviews:** Enterprise Architecture must be reviewed and updated on an annual basis. This will help baseline the constant change witnessed in Enterprise Architecture landscape.

14. Supplier Management

- a. **Purpose:** Purpose is to ensure that PFL is able to procure the best-in-class technology products and services in an objective manner, while adhering to industry best practices.
- b. **Scope:** This is applicable to all the activities of Vendor Management inclusive of vendor need identification, complete cycle of procurement and post procurement like vendor on-boarding, monitoring and exit. Subjects covered are:
 - i. IT assets related to hardware, software, networking, or communication.
 - ii. Professional services in form of consulting, advisory, solution development, maintenance, and support or staff augmentation.
 - iii. III. Procurement Pre-Requisites: Any IT procurement must be supported by the Procurement Note.
 - iv. Vendor Shortlist: PFL shall define guidelines for identification of appropriate vendors.
- c. **Outcome:** PFL shall establish and manage the supplier relationships so as to ensure quality of service provided by suppliers.
- d. **Stakeholders:** Primary ownership of IT Supplier Management lies with CTO / CIO / Head of IT or a role to whom either of these two are reporting to.
- e. **Policy Statements**
 - I. **IT Procurement Authority:** The CTO / CIO authorized delegate, shall be the primary authority for placing orders for IT hardware, software and services on behalf of PFL. For certain orders

that are strategic in nature, an approval matrix shall be in place which will indicate the involvement and concurrence of other stakeholders.

II. **Budget Applicability:**

1. Budget Approval- Should be in place either as part of annual budget or alternatively a specific approval. However, emergency procurement can be done with post facto approval.
2. There should be a separate approval matrix for non-budgeted expenditure, which need to be incurred due to changing business needs.

III. **Procurement Pre-Requisites:** Any IT procurement must be supported by the Procurement Note in the prescribed format as part of the templates to this policy. The procurement note shall be prepared by the person in charge of the concerned Technology Area

IV. **Vendor Shortlist:** PFL shall define guidelines for identification of appropriate vendors..

f. **Enforcement:** Any suspected breaches of this policy should, in the first instance, be reported to the CTO / CIO or the Head of the concerned IT portfolio

g. **Reviews:** The Policy must be reviewed at least on an annual basis.

15. **Business Continuity Planning and Disaster Recovery**

a. **Purpose:** Purpose is to protect business data in the event of disaster of any form and provide continuity of business in such events. Purpose is also to meet regulatory expectations on this aspect.

b. **Scope:** Scope of Business Continuity Planning is to conduct a Business Impact Analysis (BIA) for all business functions to identify the impact of a disaster on concerned business processes. BIA shall lead to identification of business critical applications with RTO and RPO.

c. **Outcome:** Outcome of BCP policy is BCP test report for business critical applications and Infrastructure devices, BCP plan with identified steps in case of events.

d. **Stakeholders:** Primary ownership of BCP is with the concerned Business Head for the related functional area; primary ownership of DR is with CTO / CIO / Head of IT or a role to whom either of these two are reporting to.

e. **Policy Statements**

I. **Business Continuity and Disaster recovery:**

- Information systems that are critical to the Organization's business shall be identified through a formal BIA / Risk Assessment process and planned for continuity of operations in the event of disasters. Disaster Recovery Plan/Business Continuity Plan, in line with Organization's Business Continuity plan, shall be formulated, maintained, tested, and implemented for such systems.
- The BCP plan shall provide for appropriate safeguards to minimize the risk, cost, and duration of disruption to business processes caused by disaster.
- PFL shall ensure that disaster recovery capability is in place and tested sufficiently to ensure that ability of the company to provide service to its customers and secure its revenues can continue in the event of a disaster.
- Time to recover access to the application, and the allowable data loss that can be tolerated after a disaster shall be documented for all the critical applications. The aforementioned provisions shall be read in conjunction with Business Continuity Management Policy of PFL, for the purpose of Disaster Recovery process to be carried Out.

II. **Business Impact Assessment:** Business Impact Assessment: A Business Impact Assessment (BIA) shall be carried out on annual basis to identify the critical process and their respective:

- a. Recovery Point Objective (RPO) – The point to which information used by an activity must be restored to enable the activity to operate on resumption.
- b. Recovery Time Objective (RTO) – Period of time following an incident within which,
 - a) product or service must be resumed, or
 - b) activity must be resumed, or
 - c) resources must be recovered.

RPO and RTO have significant cost implications and shall be used to right size Disaster Recovery capability. PFL shall have a defined BIA template and the primary ownership of the filled-in BIA template will be with the respective Business Process Leaders.

III. **Information Security:** PFL shall follow the defined information security policy to protect information during a disaster.

- f. **Enforcement:** Recovery testing shall be performed at least once a year for all business-critical applications
- g. **Reviews:** BCP and DR policy shall be reviewed annually.

16. Program & Project Management

- a. **Purpose:** Purpose is to ensure predictability of all IT projects on Time, Quality and Cost parameters
- b. **Scope:** Scope of IT Program and Project Management Policy is all IT projects and Programs inclusive of IT Infrastructure, Business Applications, and Innovation Projects. A Program is a set of projects with common business or technology objectives. A project is a finite set of activities with a start and definite end date spanning a duration of at least six weeks.
- c. **Outcome:** Successful delivery of all project and programs
- d. **Stakeholders:** Primary ownership of Program and Project Management of all IT projects lies with CTO / CIO.
- e. **Policy Statements:**
 - I. **Project Sponsor:** Large project shall be sponsored by the respective Head of the Business, preferably at the Business Head. They shall provide direction and resolve any issues related to company policy or business strategy/direction.
 - II. **Project Ownership:** There shall be a Business Owner of the project who will request for the budget and create the Cost Benefit Analysis as applicable. This person shall also be responsible for documenting Requirements, User Acceptance Sign off and Rollout
 - III. **Steps/Activities to be followed in each project will be:**
 - Project Initiation
 - Resource Planning
 - Project Planning
 - Project Monitoring
 - Project Closure
- f. **Enforcement:** PFL should establish a steering committee, consisting of business owners, the development team and other stakeholders to provide oversight and monitoring of the progress of the project, including deliverables to be realized at each phase of the project and milestones to be reached according to the project timetable.
- g. **Reviews:** The Policy shall be reviewed and updated on annual basis.

17. Change Management

- a. **Purpose:** Purpose of Change Management policy is to ensure each change has been adequately evaluated against impact on business, IT and Cost before being approved and implemented.
- b. **Scope:** Changes to organisation's IT assets including applications, servers and network devices shall be performed in a controlled manner to ensure that the risks associated with such changes are managed to an acceptable level. Critical changes shall be tested in non-production environment before deployment and ineffective changes shall be rolled back.

Approval for all Critical / High risk changes shall be done by Change Control Board.

For Medium / Low risk changes, which do not have wide impact/usage, the Change Control Board functions shall be carried out within Application Owner's department or IT department.

- c. **Outcome:** Successful deployment of changes without any side effects or repeat issues.
- d. **Stakeholders:** Primary ownership of Change Management lies with CTO / CIO. Change Control Board (CCB) is the enforcing authority of change management.
- e. **Policy Statements**

- I. **Following procedure shall be followed for approval of a change request.**

- Prioritize responding to change proposals from business.
- Perform cost benefit analysis of the changes proposed.
- Assess the risks associated with the changes proposed.
- Change Control Board (CCB)/Change Advisory Board (CAB) has been established for all application groups to take decisions on changes to be implemented.
- Change request should be documented and shared with appropriate authorities for review.
- Change requests should be approved before implementation.
- Changes should be compliant with statutory and legal/regulatory requirements as applicable to PFL.
- The aforementioned provisions shall be read in conjunction with Change Management Policy of PFL, for the purpose of change management process to be carried out.

- II. **Implementation of Change**

- Change should be implemented based on the implementation plan approved as part of change request.
- Post Implementation, review should be performed to confirm if the change is working as desired

- The changes shall be done in such a way that adverse incidents and disruption to services are minimized while maximizing value for the customers of PFL.
- The impact of change shall be monitored and in case of any issue, report of the same shall be placed before the CAB for its review.

III. **Documentation of Change**

- All Documents related to change request should be retained for audit purpose.
- f. **Enforcement**: The CCB/CAB will be the enforcing authority for the changes.
- g. **Reviews**: Change Management Policy shall be reviewed annually.

Policy Sections (Part B)

18. **Asset Management**

- a. **Purpose**: Purpose of Asset Management Policy is to optimally manage assets through the entire lifecycle from procurement until disposal.
- b. **Scope**: Any software, hardware, end user computing device, networking or communication components or any business application that is deployed in production environment will be classified as IT Assets and will fall under the scope of IT Asset Management Procedure.
- c. **Outcome**: Outcome of Asset Management is classification of assets based on CIA triad.
- d. **Stakeholders**: Primary ownership of Asset Management lies with Head of IT Infrastructure. Head of IT Infrastructure shall however appoint an Asset Manager within IT department to delegate this responsibility.
- e. **Policy Statements**

I. **Asset Lifecycle**

- IT asset acquisition request shall be approved by respective department head and CTO / CIO.
- All assets shall be identified, classified and protected during their whole lifecycle as per the IS Policy – Asset Management.
- The IT assets shall have a unique identification code and it should be maintained in the centralized database.

- In case the retired IT assets needs to be destroyed, the process for disposal of media should be followed.
- Asset inventory should be updated upon acquisition, retirement and disposal of assets.

II. **Asset Records**

- An inventory of all IT assets shall be maintained and updated. The inventory should at least include the details of unique asset identification number, the asset owner, contact details, asset allocation period.
- An inventory of all software licenses shall be maintained and updated in the database.

III. **Asset Review**

- The inventory of assets shall be reviewed at least annually.
- The inventory of software licenses shall be reviewed at least annually.

f. **Enforcement:** CTO / CIO will be the enforcing Authority for IT Asset Management Policy.

g. **Reviews:** Asset Management Policy must be reviewed at least annually.

19. **Incident & Problem Management**

Procedures shall be developed and implemented to effectively manage the process for identification and management of IT Incidents & Problems. The process should detail the following aspects of IT Incident and Problem Management:

19.1. **Incident Management:**

- Incident detection and recording
- Classification and initial support
- Investigation and analysis
- Resolution and record
- Incident closure
- Incident ownership, monitoring, tracking and communication
- Establish incident framework management
- Evaluation of incident framework management.

19.2. **Problem Management**

- Problem detection

- Problem logging
- Problem prioritization
- Problem investigation and diagnosis
- Major problem review

20. Backup and Archival

- Purpose:** Purpose is to safeguard PFL data against events such as corruption, virus attacks or malfunctioning of production environment in Data Centre and cloud environment.
- Scope:** Scope of Backup and Archival policy is primarily the data stored on PFL infrastructure.
- Outcome:** Outcome of Backup and Archival policy is periodic backup and archival drill reports to ensure compliance.
- Stakeholders:** Primary ownership of this policy lies with CTO / CIO.

CTO / CIO shall however appoint Head of IT Infrastructure to delegate this responsibility.

e. **Policy Statements**

- Backup Information:** PFL shall backup all information residing in:
 - Application Databases, Application Code & Operating System Files.
 - Shared Folders, Document Management System.
 - Active Directory, Network & Security Device Configurations.
- Backup Schedule:** PFL shall prepare a backup schedule identifying the type (full/ incremental) and frequency of backup.
- Backup Media:** All information shall be backed up onto a secondary storage.
- Backup Data Access:** Access to the Backup Media shall be restricted to authorized personnel from IT department.
- Backup Data Retention:** A retention schedule shall be defined that is in agreement with the respective information owner and in compliance with applicable regulations and standards.
- Backup Data Restoration:** A formal request for restoration shall be raised by the user requiring restoration of data.
- Backup Data Validation:** Restoration testing shall be conducted for the backed-up data on regular basis to check the integrity and adequacy of the backup.

- viii. **Backup Monitoring:** A monitoring mechanism shall be put in place to ensure that backup is taken successfully, and any failures are actioned upon.
- ix. **Backup of Data on End User Devices:** Backup of critical business data residing on end user devices such as desktops/laptops shall be the responsibility of the respective user.
- f. **Enforcement:** CTO / CIO shall be the enforcing Authority for backup and Archival Policy.
- g. **Reviews:** Backup and Archival Policy must be reviewed at least annually.

21. User Collaboration & Email

- a. **Purpose:** To enable collaboration among PFL users by providing timely access to information.
- b. **Scope:** Scope is to ensure right allocation and management of emails for PFL users. Where possible alternate modes of communication shall be encouraged through an employee portal.
- c. **Stakeholders:** Primary ownership lies with CTO / CIO.

CTO / CIO shall however appoint Head of IT Infrastructure to delegate this responsibility.
- d. **Policy Statements**
 - i. **Email Client:** PFL shall use licensed and authorized version of email client.
 - ii. **Access:** Employees shall be provided with access to email based on the business purpose involved. Under exceptional circumstances, email access is provided to contract staff/ temporary staff on the basis of explicit approval of their reporting managers, Head of IT and Infosec.
 - iii. **Group email ID:** Group email id shall be provided on the basis of approval from respective business unit heads.
 - iv. **Mail size:** PFL shall define guidelines for mailbox size, incoming/outgoing mail size based on the designation of the employee and the business function performed. Mailbox size can be increased with explicit approval of respective business division head and CTO / CIO.
 - v. **Disclaimer:** PFL shall define a disclaimer that is appended to all outgoing mail.
 - vi. **Deactivation of Email:** PFL shall define process for delegation / deactivation of mailbox on employee exit.
 - vii. **Anti-Virus & Anti-spam:** All mails shall be scanned at the gateway for virus and spam messages. All messages containing virus shall be blocked and deleted at the gateway. All messages blocked by anti-spam solution shall be retained on the mail server for a specified duration as per the defined guidelines.

- viii. **Email logging:** Logs of all emails sent/ received would be maintained and retained for a period of 7 days. The log would capture the sender, receiver, time, data and subject details. Access to the logs would be restricted only to authorized individuals in the Email Operations team.
- ix. **Webmail & Mobile access:** PFL provides access to Official Mails on web browser & on mobile client for PFL employees to access mail on the move. The policies in this document are applicable for access to mail via web browser and through mobile client.
- x. **Backup & Restoration:** For Office 365 users 1 month mail retention for deleted mails / mailboxes is offered by service provider.
- xi. **Email Archival:** Archival of mailbox shall be done based on business or statutory requirement, with approval of the Business Head and CTO / CIO.
- e. **Enforcement:** CTO / CIO shall be the enforcing Authority.
- f. **Reviews:** Email Policy must be reviewed at least annually.

IT Outsourcing. All the IT Outsourcing arrangements shall comply with the Outsourcing Policy of the Company. Where third-party arrangements in the Information Technology/ Cyber Security ecosystem are not within the applicability of the Reserve Bank of India (Outsourcing of Information Technology Services) Directions, 2023, PFL shall ensure appropriate vendor risk assessment process and controls proportionate to the assessed risk and materiality to, inter alia: (a) mitigate concentration risk; (b) eliminate or address any conflict of interests; (c) mitigate risks associated with single point of failure; (d) comply with applicable legal, regulatory requirements and standards to protect customer data; (e) provide high availability (for uninterrupted customer service); and (f) manage supply chain risks effectively.

22. Management Information System.

a. **Policy Statement**

The IT function of PFL should support a robust and comprehensive Management Information System (MIS) in respect of various business functions as per the needs of the business. A good MIS should take care of information needs at all levels in the business including top management.

PFL may put in place MIS that assist the Top Management as well as the business heads in decision making and also to maintain an oversight over operations of various business verticals. With robust IT systems in place, PFL may have the following as part of an effective system generated MIS (indicative list)

- a) A dashboard for the Top Management summarising financial position vis-à-vis targets. It may include information on trend on returns on assets across categories, major growth business segments, movement of net-worth etc.
- b) System enabled identification and classification of Special Mention Accounts and NPA as well as generation of MIS reports in this regard.
- c) The MIS should facilitate pricing of products, especially large ticket loans.
- d) The MIS should capture regulatory requirements and their compliance.
- e) Financial Reports including operating and non-operating revenues and expenses, cost benefit analysis of segments/verticals, cost of funds, etc. (also regulatory compliance at transaction level)
- f) Reports relating to treasury operations.
- g) Fraud analysis- Suspicious transaction analysis, embezzlement, theft or suspected money-laundering, misappropriation of assets, manipulation of financial records etc. The regulatory requirement of reporting fraud to RBI should be system driven.
- h) Capacity and performance analysis of IT security systems
- i) Incident reporting, their impact and steps taken for non -recurrence of such events in the future.

MIS for Supervisory requirements - The MIS that help management in taking strategic decisions shall also assist in generating the required information/returns for the supervisor. The present structure of reporting system (to the supervisor) needs to be kept in view while designing the MIS. All regulatory/supervisory returns should be system driven; there should be seamless integration between MIS system of the PFL and reporting under COSMOS/ XBRL. Further, it is essential that "Read Only" access be provided to RBI Inspectors.

23. IT Risk Management

a. Policy Statement

PFL shall ensure that a standard IT risk management process which ensures compliance with functional, security, performance and applicable regulatory requirements is followed for all IT assets/processes/services. The goal of IT risk management policy is to protect the organization and its ability to perform their mission, not just IT assets.

b. Standards

Risk Identification, Assessment, Mitigation and Reporting

- A risk assessment methodology should be identified that is suitable to PFL and its identified information security, legal, statutory, and regulatory requirements.
- Information Security risk should be identified, assessed, mitigated, and reported based on the risk management framework defined in the Risk Management Policy/procedure.
- Business Continuity risk should be identified, assessed, mitigated, and reported based on the Risk management framework defined in the Risk Management Policy/procedure.
- IT risk assessment including IS risk should be brought to the notice of the Chief Risk Officer (CRO), CTO, CIO and the Board of directors.
- IT risk assessment should be conducted at least once on yearly basis to find out the risks present and to determine the appropriate level of controls necessary for appropriate mitigation of risks.
- Board and top management to take into consideration risks associated with planned IT operations and risk tolerance of the company.

24. Capacity Management

a. Policy Statement

- PFL shall develop procedure documents for capacity monitoring covering servers and network devices.
- PFL shall have process to ensuring that IT resources, such as servers, storage, network, are sufficient to meet the current and future demands of PFL business.
- Capacity management involves monitoring, analyzing, optimizing, and planning the use of existing capacity and making informed decisions about future investments.
- PFL shall ensure that information systems and infrastructure are able to support business functions and ensure availability of all service delivery channels.
- PFL shall on an annual or more frequent basis, proactively assess capacity requirement of IT resources.
- PFL shall ensure that IT capacity planning across components, services, system resources, supporting infrastructure is consistent with past trends (peak usage), the current business requirements and projected future needs as per the IT strategy of PFL.
- The assessment of IT capacity requirements and measures taken to address the issues shall be reviewed by the ITSC.

25. Acceptable Usage

a. Policy Statement

- IT assets of Organization are provided for business purposes and authorized users shall adhere to safe and acceptable usage practices that do not disrupt business or bring disrepute to organization.
- Standards shall be defined for safe and acceptable usage of assigned IT resources and privileges including desktops, computer accounts, business applications, computer networks and protection of information in physical or logical form and maintenance of Intellectual Property Rights by the users of information systems.

26. IT Training

- IT training shall be provided to employees as when required.
- The purpose of IT training is to ensure that users are aware of technology which are in use and are equipped to support organization's operations in their normal day-to-day work.

27. Web Presence (Intranet & Internet) and Communications.

a. Policy Statement

- PFL shall have its web presence through its own websites and Social Networking Sites. Single domain name policy for own websites shall be adopted and implemented.
- PFL shall have a website content management process to ensure that the information published on websites is accurate, consistent, and current.
- Employees having social networking sites user accounts shall adhere to web browsing practices that do not bring Organization into disrepute.
- PFL shall handle social media risks and threats. Proper controls, such as encryption and secure connections, should be prevalent to mitigate such risks.
- PFL shall manage its IT resources to protect against incidents including Website defacement, Web Identity theft, Denial of Service to ensure that Organization's reputation is protected in all manners.

28. Policy Governance

28.1.Roles & Responsibilities

#	Role	Responsibility
1.	Project Manager	Person responsible for planning, execution, closing of any project and achieving the stated project objectives.

2.	Program Manager	Person responsible for managing a set of related projects spanning one or more business domains.
3.	Business Owner (for a Project/Program)	Person who represents the primary business user community for the project. This person would usually report in to the Business Head who is the Business Sponsor for the program/project
4.	Application Owner	Senior most person associated with a project/program. An Application Owner is usually involved in all projects and changes impacting the Business Application(s) he/she is responsible for. When used generically, this term shall also include the Data Centre Manager (#13 below).
5.	Head Application Portfolio	Person responsible for several business application assets. All the three roles above would usually fold into this role.
6.	Head of IT Architecture	Person responsible for defining and implementing the Enterprise Architecture framework and in assuring that all the 5 Architectural Domains are in adherence with the Business-IT Strategy.
7.	Head of Information Security	As provided in the Information Security Policy of the Company.
8.	Head of Infrastructure	Person responsible for implementing and managing the IT infrastructure including Data Centre, Networks and End User Computing.
9.	IT Portfolio Owners	Term generically used to refer #5, #6 and #7 together
10.	IT Asset Manager	Person responsible for procurement and tracking IT hardware/software assets other than Business Applications.
11.	Infrastructure Asset Owner	Person responsible for managing infrastructure assets such as Networks, Servers, Storage etc.
12.	Application Support Manager	Person responsible for day-to-day handling of incidents at the first level (L1); incidents may be related to infra or business applications.
13.	Data Centre Manager	Person responsible for day-to-day management of data Centre; reports to Head of Infrastructure

28.2. Bodies of Governance (BOG)

Short Form	Full Form	Terms of Reference	Chairperson	Executive Members	Frequency of Meetings
ITSC	IT Strategy Committee (ITSC)	As per the Board approved Charter of the Committee.	Non-Executive Independent Director	Refer section 7 – Composition of IT Strategy Committee	Atleast Quarterly
CCB/CAB	Change Control Board/Change Advisory Board	Change Management governance body to discuss the changes related to a Business Application and their causes and impact and approval of the changes. Agenda to cover upcoming changes and projects too.	CTO / CIO	Business Owner/Representatives, Head Application Portfolio, Head of Infrastructure, Head of Information Security	Weekly
ITSgC	IT Steering Committee	As provided in this policy.	CIO/CTO	Refer section 8 – Composition of IT Steering Committee	As and when required (at least on a

					quarterly basis).
--	--	--	--	--	-------------------

28.3.RACI Matrix

The RACI Matrix below shows Responsibility and Accountability in individual areas.

#	Policy	Responsible	Accountable	Consulted	Informed
Part A					
1.	IT Strategy & Planning	IT Head	CTO / CIO	Head of Information Security	ITSC
2.	Enterprise Architecture	IT Head	CTO / CIO	Head of Information Security	ITSC
3.	Supplier Management	IT Portfolio Owners	CTO / CIO	Head of Information Security	ITSC
4.	Business Continuity Planning and Disaster Recovery	Head of Infrastructure, Application Owner, Respective Business Process Leaders	CISO for DR Respective Business Heads for BCP	CTO / CIO	ITSC
5.	Project Management	Project Manager/Application Owner	CTO / CIO	Business Owner	ITSC
6.	Change Management	Project Manager/Application Owner	CTO / CIO	IT Governance	CAB
Part B					
7.	IT Asset Management	Data center lead, IT Infra lead	Head of Infrastructure	CTO / CIO	IT Governance
8.	Incident Management	Infrastructure Asset Owner, Application Support Manager (for Business Applications)	Head of Infrastructure, Head of Application Portfolio	CTO / CIO	IT Governance and Infosec
9.	Problem Management	Infrastructure Asset Owner, Respective Application Owners (for Business Applications)	Head of Infrastructure, Head of Application Portfolio	CTO / CIO	IT Governance and Infosec
10.	Release Management	Infrastructure Asset Owner, Respective Application Owners (for Business Applications)	Head of Infrastructure, Head of Application Portfolio	CTO / CIO	IT Governance and Infosec

11.	Service Request Management	Infrastructure Asset Owner, Respective Application Owners (for Business Applications)	Head of Infrastructure, Head of Application Portfolio		
12.	Availability Management	Infrastructure Asset Owner, Respective Application Owners (for Business Applications)	Head of Infrastructure, Head of Application Portfolio	CTO / CIO	
13.	Backup and Archival	Data Centre Manager	Head of Infrastructure	Head of Infosec, Application Owners	CTO / CIO
14.	User Collaboration & Email	Data Centre Manager	Head of Infrastructure	CTO / CIO	

Classification / INTERNAL

28.4. Annexure A

Policy for management of Information Technology is backed by supporting Standards, Guidelines, Standard Operating Procedures (SOP) and Templates. The table below provides the mapping. X sign in a cell denotes the applicability of the document(s) for the policy.

Sl.No	Policy Title	Procedure	Template	Standard	Guideline
1	Supplier Management	1. SOP for Supplier Management	1. Vendor evaluation template 2. Contract and Agreements related templates	-	Vendor Management Guideline
2	Business Continuity Planning and Disaster Recovery	1. SOP for BIA 2. SOP for BCP Plan	1. BIA Template 2. Applications template with RTO and RPO	-	-
3	Project Management	SOP for Project Management	1. BRS template 2. Design Review Checklist 3. UAT Test case template 4. Deployment checklist 5. Project review template 6. Project and Program dashboard template	-	-
4	Change Management	SOP for Change Management	1. Change Request (CR) Template 2. Change Dashboard template	-	-

			3. Change review template 4. Templates as implemented in MSD.		
5	Asset Management	Asset Management SOP	1. Asset Inventory template 2. Asset retiring/disposal/refresh template 3. Asset transfer template	-	Asset allocation Guidelines
6	Incident Management	Incident Management SOP	Templates as implemented in MSD	ITIL	-
7	Problem Management	Problem Management SOP	Templates as implemented in MSD	ITIL	-
8	Release Management	Release Management SOP	Templates as implemented in MSD	ITIL	-
9	Service Request Management	Service request Management	Templates as implemented in MSD	ITIL	-
10	Availability Management	Availability Management SOP	Templates as implemented in MSD	ITIL	-
11	Backup and Archival	Back up SOP for each application and emails	SOP for backup	-	-

Abbreviations

ITSC – IT Governance committee

SOP – Standard Operation procedure

SLA – Security level Agreement

RPO – Recovery point Objective

RTO – Recovery time Objective

BIA – Business Impact Assessment

BCP – Business continuity plan

DR – Disaster Recovery

CCB – Change Control Board

ITSgC – IT Steering Committee

BOG – Body of Governance

CR – Change Request

PFL – Poonawalla Fincorp Ltd.

Classification | INTERNAL